

EU AI Act: Was KMU jetzt wissen müssen

Deep Researcher (deep-research.leon.fm)

2026-04-01

Contents

EU AI Act: Was KMU jetzt wissen müssen	1
Kernaussagen	1
Der EU AI Act im Überblick	1
Was bedeutet das für KMU?	3
Praktische Schritte zur Compliance	5
Kosten und Konsequenzen	6
Offene Fragen und Ausblick	8

EU AI Act: Was KMU jetzt wissen müssen

Kernaussagen

- Die KI-Verordnung (EU) 2024/1689¹ gilt seit 1. August 2024 und wird stufenweise durchgesetzt — die **KI-Kompetenzpflicht gilt bereits seit Februar 2025**, auch für KMU, die KI nur einsetzen.
- Es gibt **keine pauschale Befreiung** für kleine Unternehmen. Entscheidend ist die Risikoklasse des KI-Systems, nicht die Unternehmensgröße. Allerdings profitieren KMU von reduzierten Bußgeldern, vereinfachter Dokumentation und kostenlosem Sandbox-Zugang².
- Der Digital Omnibus³ verschiebt die Hochrisiko-Fristen auf Dezember 2027 bzw. August 2028 — aber die bereits geltenden Pflichten bleiben unverändert.
- Geschätzte Compliance-Kosten für KMU-Anbieter von Hochrisiko-KI liegen bei 200.000–300.000 EUR⁴, doch EU- und nationale Förderprogramme können diese erheblich senken.
- Die meisten KMU sind **Betreiber**, nicht Anbieter — mit deutlich geringerem Pflichtumfang. Aber Vorsicht: Fine-Tuning oder Umbenennung können KMU unbeabsichtigt zum Anbieter machen⁵.

Der EU AI Act im Überblick

Was ist die KI-Verordnung?

Die Verordnung (EU) 2024/1689⁶ — kurz EU AI Act — ist das weltweit erste umfassende Regulierungswerk für Künstliche Intelligenz. Sie wurde am 13. Juni 2024 unterzeichnet, am 12. Juli

¹[EU AI Act Volltext \(EUR-Lex\)](#) — Behördenbericht, Juli 2024

²[EU AI Act Service Desk — Artikel 62](#) — Behördenbericht, laufend

³[Ebner Stolz — Digital Omnibus Analyse](#) — Branchenbericht, März 2026

⁴[CEPS — Costs for the EU's AI Act](#) — Branchenbericht, 2023

⁵[HÄRTING — Provider or Deployer?](#) — Branchenbericht, 2025

⁶[EU AI Act Volltext \(EUR-Lex\)](#) — Behördenbericht, Juli 2024

2024 im Amtsblatt veröffentlicht und trat am 1. August 2024 in Kraft. Die Verordnung gilt unmittelbar in allen EU-Mitgliedstaaten, ohne dass nationale Umsetzungsgesetze erforderlich wären.

Stufenweise Durchsetzung

Die Anwendung erfolgt gestaffelt, um Unternehmen Vorbereitungszeit zu geben:

Datum	Was gilt
2. Februar 2025	Verbote inakzeptabler KI-Praktiken (Art. 5); KI-Kompetenzpflicht (Art. 4)
2. August 2025	Governance-Regeln; Pflichten für Allzweck-KI-Modelle (GPAI)
2. August 2026	Vollständige Anwendbarkeit: Hochrisiko-KI (Anhang III), Transparenzpflichten (Art. 50)
2. August 2027	Hochrisiko-KI als Sicherheitskomponenten in regulierten Produkten (Anhang I)

7

Wichtig: Der Digital Omnibus⁸, im März 2026 vom EU-Parlament angenommen, verschiebt die Hochrisiko-Fristen: Eigenständige Hochrisiko-KI auf den **2. Dezember 2027**, in Produkte eingebettete Hochrisiko-KI auf den **2. August 2028**. Hintergrund: Die harmonisierten technischen Standards werden voraussichtlich nicht vor Ende 2026 verfügbar sein. Die Änderungen befinden sich derzeit im Trilog-Verfahren und sind noch nicht finalisiert.

Vier Risikokategorien

Der AI Act verfolgt einen risikobasierten Ansatz. Je höher das Risiko eines KI-Systems, desto strenger die Anforderungen:

Inakzeptables Risiko (verboten): KI-Systeme, die als Bedrohung für Grundrechte gelten – Social Scoring, manipulative Techniken, Echtzeit-Biometrie in öffentlichen Räumen⁹ (mit eng definierten Ausnahmen für Strafverfolgung), prädiktives Policing auf reiner Profiling-Basis, Emotionserkennung am Arbeitsplatz und in Bildungseinrichtungen. Insgesamt acht verbotene Praktiken, die seit dem 2. Februar 2025 gelten.

Hohes Risiko: KI in sensiblen Bereichen wie Personalmanagement, Kreditwürdigkeit, Bildung, kritische Infrastruktur, Strafverfolgung und Migration¹⁰. Strenge Anforderungen an Risikomanagement, Datenqualität, technische Dokumentation, menschliche Aufsicht und Genauigkeit.

Begrenztes Risiko (Transparenzpflichten): Chatbots müssen als KI gekennzeichnet werden¹¹, Deepfakes als KI-generiert, Emotionserkennung als solche offengelegt.

⁷[EU-Kommission – Regulatory Framework for AI](#) – Behördenbericht, laufend aktualisiert
⁸[Ebner Stolz – Digital Omnibus Analyse](#) – Branchenbericht, März 2026
⁹[AI Act High-Level Summary](#) – Official Documentation, laufend aktualisiert
¹⁰[AI Act High-Level Summary](#) – Official Documentation, laufend aktualisiert
¹¹[Mittelstand-Digital – AI Act Überblick](#) – Behördenbericht, 2025

Minimales Risiko: Die Mehrheit aller KI-Systeme (Spamfilter, Empfehlungsalgorithmen, Rechtschreibprüfung). Keine spezifischen Pflichten — lediglich freiwillige Verhaltenskodizes.

Wer ist betroffen?

Der AI Act definiert vier zentrale Rollen¹² mit abgestuften Pflichten:

- **Anbieter (Provider):** Entwickeln KI-Systeme und bringen sie unter eigenem Namen in Verkehr. Umfangreichste Pflichten: Konformitätsbewertung, technische Dokumentation, Qualitätsmanagement, CE-Kennzeichnung, Marktüberwachung. Dokumentation 10 Jahre aufbewahren.
- **Betreiber (Deployer):** Setzen KI-Systeme unter eigener Verantwortung beruflich ein. Pflichten: Nutzung gemäß Herstelleranweisungen, menschliche Aufsicht, Protokollaufbewahrung (mind. 6 Monate), Information betroffener Personen.
- **Einführer (Importer):** Bringen KI-Systeme von Nicht-EU-Anbietern auf den EU-Markt. Pflichten: Überprüfung der Konformität.
- **Händler (Distributor):** Stellen KI-Systeme auf dem Markt bereit. Pflichten: Verifizierung von CE-Kennzeichnung und Dokumentation.

Der AI Act gilt **extraterritorial**: Auch Nicht-EU-Unternehmen sind betroffen, wenn ihre KI-Systeme in der EU eingesetzt werden oder ihre Outputs Personen in der EU betreffen.

Was bedeutet das für KMU?

Keine pauschale Befreiung

Ein verbreitetes Missverständnis: Es gibt keine KMU-Befreiung¹³. Ein Drei-Personen-Startup, das Hochrisiko-KI auf den EU-Markt bringt, unterliegt denselben inhaltlichen Anforderungen wie ein Konzern. Die Erleichterungen betreffen Gebühren, Dokumentationsformat und Zugang zu Unterstützung — nicht den Schutzstandard selbst.

Anbieter oder Betreiber? Die entscheidende Frage

Die meisten KMU sind **Betreiber**: Sie nutzen KI-Tools (ChatGPT, KI-gestützte Buchhaltung, CRM mit KI-Funktionen), entwickeln diese aber nicht selbst. Der Pflichtumfang als Betreiber ist deutlich geringer als für Anbieter¹⁴.

Achtung — Rollenumklassifizierung: Ein Betreiber wird zum Anbieter (mit vollen Anbieterpflichten), wenn er: - ein KI-System unter eigenem Namen oder eigener Marke vermarktet, - wesentliche Änderungen am System vornimmt, oder - den Verwendungszweck so ändert, dass eine Hochrisiko-Einstufung ausgelöst wird.

Besonders relevant für KMU: Fine-Tuning eines bestehenden Modells löst volle Anbieterpflichten aus, wenn der Rechenaufwand mindestens ein Drittel des ursprünglichen Trainingsaufwands

¹²[Glocert — Operator Roles](#) — Branchenbericht, 2025

¹³[Privacy Needle — Why Small Startups Are Not Exempt](#) — Blogbeitrag, 2025

¹⁴[HÄRTING — Provider or Deployer?](#) — Branchenbericht, 2025

¹⁵[Hugging Face — EU AI Act Open Source Guide](#) — Branchenbericht, 2025

übersteigt¹⁵. Unterhalb dieser Schwelle gelten eingeschränkte Dokumentationspflichten für die eigenen Modifikationen.

KMU-spezifische Erleichterungen

Artikel 62 der Verordnung¹⁶ verpflichtet Mitgliedstaaten zu konkreten Unterstützungsmaßnahmen:

- **Vereinfachte Dokumentation:** KMU dürfen statt der vollen Annex-IV-Dokumentation ein vereinfachtes Formular verwenden¹⁷, das die EU-Kommission bereitstellen muss (noch nicht veröffentlicht, Stand April 2026).
- **Priorisierter Sandbox-Zugang:** Jeder Mitgliedstaat muss bis August 2026 mindestens eine Regulatory Sandbox einrichten, zu der KMU kostenlosen Zugang erhalten¹⁸.
- **Reduzierte Gebühren:** Konformitätsbewertungsgebühren werden proportional zur Unternehmensgröße gesenkt.
- **Dedizierte Kommunikationskanäle:** Spezifische Beratungsangebote für KMU bei nationalen Behörden.
- **Befreiung von Stakeholder-Konsultation:** KMU müssen bei der Grundrechte-Folgenabschätzung keine externen Stakeholder konsultieren¹⁹.

Der Digital Omnibus erweitert diese Erleichterungen auf „Small Mid-Cap“-Unternehmen mit bis zu 750 Mitarbeitern und unter 150 Mio. EUR Umsatz²⁰.

Open-Source-KI: Was gilt für KMU?

Open-Source-GPAI-Modelle sind unter bestimmten Bedingungen von Dokumentationspflichten befreit²¹: freie Lizenz (Apache 2.0, MIT – nicht „Research Only“), öffentliche Verfügbarkeit der Gewichte und Architektur, und keine Monetarisierung. Aber: Urheberrechtspolitik und Trainingsdaten-Zusammenfassung müssen immer erfüllt werden²².

Für KI-Systeme (nicht nur Modelle) gilt eine breitere Open-Source-Ausnahme nach Art. 2(12)²³ – es sei denn, das System ist hochriskant, verboten oder fällt unter Transparenzpflichten.

Wichtig für KMU, die Open-Source-Modelle kommerzialisieren wollen: Die Ausnahme erlischt bei Monetarisierung²⁴. API-Gebühren oder Lizenzgebühren gelten klar als kommerziell. Kostenpflichtiger Support liegt in einer Grauzone.

¹⁶[EU AI Act Service Desk – Artikel 62](#) – Behördenbericht, laufend

¹⁷[Holistic AI – SME Support](#) – Branchenbericht, 2024

¹⁸[AI Act – Artikel 57 \(Sandboxes\)](#) – Official Documentation, 2024

¹⁹[Holistic AI – SME Support](#) – Branchenbericht, 2024

²⁰[Cooley – Digital Omnibus Impact](#) – Branchenbericht, November 2025

²¹[Hugging Face – EU AI Act Open Source Guide](#) – Branchenbericht, 2025

²²[Hugging Face – EU AI Act Open Source Guide](#) – Branchenbericht, 2025

²³[Linux Foundation Europe – AI Act Explainer](#) – Branchenbericht, 2025

²⁴[Secjur – EU AI Act und Open-Source-Entwickler](#) – Branchenbericht, 2025

Praktische Schritte zur Compliance

1. KI-Kompetenz sicherstellen (gilt seit Februar 2025)

Die KI-Kompetenzpflicht nach Artikel 4²⁵ gilt bereits jetzt – auch für KMU, die KI nur gelegentlich einsetzen (z. B. ChatGPT, KI-gestützte Buchhaltungssoftware). Das AI Office stellt klar: „There is no one size fits all when it comes to AI literacy.“ Es gibt keine vorgeschriebenen Zertifikate oder Pflichtschulungen. Stattdessen müssen Maßnahmen kontextbezogen sein und vier Faktoren berücksichtigen: technisches Vorwissen, Erfahrung, Ausbildung der Mitarbeitenden und Einsatzkontext. Nur Bedienungsanleitungen bereitzustellen reicht ausdrücklich **nicht**.

Die IHK Schleswig-Holstein empfiehlt²⁶ ein vierstufiges Vorgehen: (1) Bedarfsanalyse – eingesetzte KI-Systeme und betroffene Mitarbeitende identifizieren, (2) Schulungskonzepte – Grundlagen-Workshops und fachspezifische Trainings, (3) interne KI-Richtlinien erstellen, (4) einen KI-Beauftragten ernennen. Obwohl keine formale Nachweispflicht besteht, wird dringend empfohlen, Schulungsmaßnahmen zu dokumentieren – bei Verstößen drohen zivilrechtliche Risiken.

2. KI-Inventur durchführen

Bevor eine Risikoklassifizierung möglich ist, müssen alle KI-Systeme im Unternehmen erfasst werden – auch eingebettete KI-Funktionen in ERP, CRM, HR-Software und Cloud-Diensten²⁷.

3. Risikoklassifizierung und Rollenbestimmung

Für jedes identifizierte KI-System: Gegen die vier Risikostufen prüfen, Anhang III für die Liste der Hochrisiko-Bereiche konsultieren²⁸ und die eigene Rolle klären (Anbieter, Betreiber, Einführer). Wer ein System als nicht hochriskant einstuft, muss diese Bewertung dokumentieren, bevor das System auf den Markt kommt²⁹.

4. Governance und Dokumentation aufbauen

Bis August 2026³⁰ sollten KMU: Verantwortliche für KI-Compliance benennen, Verträge mit KI-Anbietern auf Konformität prüfen, bestehende Compliance-Strukturen nutzen – eine DSGVO-Datenschutzfolgenabschätzung kann mit der KI-Grundrechtfolgenabschätzung kombiniert werden³¹, und KI-Sicherheit sollte ins bestehende ISMS integriert werden (Prompt Injection, Data Poisoning in die Risikoanalyse aufnehmen).

Empfohlene Roadmap für KMU

Zeitraum	Maßnahme
Sofort	KI-Kompetenz-Schulungen durchführen (Pflicht seit Feb. 2025)

²⁵[EU-Kommission – AI Literacy FAQ](#) – Behördenbericht, 2025

²⁶[IHK Schleswig-Holstein – KI-Schulungspflicht](#) – Branchenbericht, 2025

²⁷[Sage – EU AI Act für den Mittelstand](#) – Branchenbericht, 2026

²⁸[Sage – EU AI Act für den Mittelstand](#) – Branchenbericht, 2026

²⁹[AI Act High-Level Summary](#) – Official Documentation, laufend aktualisiert

³⁰[Orrick – 6 Steps Before August 2026](#) – Branchenbericht, November 2025

³¹[ing-ism.de – Informationssicherheit und AI Act](#) – Branchenbericht, 2025

Zeitraum	Maßnahme
Sofort	KI-Inventur: Alle KI-Systeme im Unternehmen dokumentieren
Bis Mai 2026	Risikoklassifizierung und Rollenbestimmung abschließen
Bis August 2026	Governance-Struktur, Dokumentation und Risikomanagement aufbauen
Bis Dezember 2027	Volle Compliance für eigenständige Hochrisiko-KI (Annex III)*
Bis August 2028	Volle Compliance für eingebettete Hochrisiko-KI (Annex I)*

*Fristen gemäß Digital Omnibus; Trilog-Verhandlungen laufen noch.

Kosten und Konsequenzen

Bußgelder: Dreistufiges System mit KMU-Schutzklausel

Der Artikel 99 der KI-Verordnung³² sieht drei Bußgeldstufen vor:

Verstoß	Obergrenze
Verbotene KI-Praktiken (Art. 5)	35 Mio. EUR oder 7 % des weltweiten Jahresumsatzes
Andere Verstöße (z. B. Hochrisiko-Pflichten)	15 Mio. EUR oder 3 % des Umsatzes
Falsche/unvollständige Angaben an Behörden	7,5 Mio. EUR oder 1 % des Umsatzes

Für Großunternehmen gilt jeweils der **höhere** Betrag. Für KMU und Startups gilt eine explizite Schutzklausel: der jeweils **niedrigere** Betrag³³. Beispiel: Ein KMU mit 5 Mio. EUR Umsatz riskiert bei einem Verstoß gegen verbotene Praktiken maximal 350.000 EUR (7 % von 5 Mio.) statt 35 Mio. EUR.

Neun Bemessungskriterien³⁴ beeinflussen die tatsächliche Höhe: Schwere und Dauer des Verstoßes, Vorsatz vs. Fahrlässigkeit, Kooperation mit Behörden, dokumentierte Compliance-Maßnahmen und ergriffene Schadensbegrenzung. Proaktives Compliance-Verhalten kann die Strafe erheblich senken.

Geschätzte Compliance-Kosten

Die Kostenschätzungen variieren erheblich je nach Quelle und Perspektive:

³² [AI Act Law – Artikel 99 \(Bußgelder\)](#) – Official Documentation, 2024

³³ [AI Act Law – Artikel 99 \(Bußgelder\)](#) – Official Documentation, 2024

³⁴ [Secjur – Bußgeld-Berechnung](#) – Branchenbericht, o. D.

- **EU-Kommission (Minimalschätzung):** ca. 6.000–7.000 EUR pro Hochrisiko-KI-System³⁵ für Anbieter. Betreiber: 5.000–8.000 EUR/Jahr für menschliche Aufsicht. Konformitätsbewertung durch Dritte: 3.000–7.500 EUR.
- **QMS-Aufbau (größter Einzelposten):** 193.000–330.000 EUR initial, 71.400 EUR/Jahr Wartung³⁶ — deutlich reduziert für Unternehmen mit bestehenden ISO-Zertifizierungen.
- **Intellera-Consulting-Studie:** 229.000–301.000 EUR Gesamtkosten³⁷ für ein durchschnittliches KMU als KI-Anbieter, je nach Nutzung von EU-Unterstützungsinfrastruktur.

Zum Vergleich: Die DSGVO-Compliance kostete KMU im Durchschnitt rund 130.000 EUR. Der AI Act wird teurer geschätzt, weil neben Dokumentation auch technische Anforderungen an die KI-Systeme selbst gestellt werden.

[Under-sourced] Die genannten Kostenschätzungen basieren auf Modellrechnungen, nicht auf empirischen Erhebungen bei betroffenen Unternehmen. Belastbare Umfragen unter deutschen KMU zu tatsächlichen Compliance-Kosten liegen noch nicht vor.

Fördermöglichkeiten

Mehrere Programme adressieren gezielt die Compliance-Kosten:

European Digital Innovation Hubs (EDIHs): Die EU finanziert 83 EDIHs mit insgesamt 342 Mio. EUR³⁸ (2025–2027), die als „First-line AI Helpdesks“ kostenlose Beratung, Testinfrastruktur und Zugang zu Experten bieten.

Regulatory Sandboxes: Jeder Mitgliedstaat muss bis August 2026 mindestens eine einrichten. KMU erhalten kostenlosen Zugang und sind bei gutem Glauben vor Verwaltungsstrafen geschützt³⁹.

Bavarian AI Act Accelerator: Bayern fördert mit 1,6 Mio. EUR ein Programm⁴⁰ (bis Dezember 2026), das KMU bei Risikoklassifizierung, Dokumentation und Trainings unterstützt — getragen von appliedAI, LMU und TU München.

Mittelstand-Digital Zentren: Das BMWK-Programm⁴¹ bietet kostenlose Beratungen, Workshops und KI-Trainer für KMU.

BridgeAI: Ein BMWK-gefördertes Projekt⁴² mit modularen Schulungsmodulen, Kompetenztest und Lernpfaden, zugeschnitten auf Vorkenntnisse und Rolle.

³⁵ [CEPS — Costs for the EU's AI Act](#) — Branchenbericht, 2023

³⁶ [CEPS — Costs for the EU's AI Act](#) — Branchenbericht, 2023

³⁷ [Digital SME Alliance — AI Act: Help or Hindrance?](#) — Branchenbericht, 2024

³⁸ [EU-Kommission — EDIH Funding \(342 Mio. EUR\)](#) — Behördenbericht, Oktober 2025

³⁹ [AI Act — Artikel 57 \(Sandboxes\)](#) — Official Documentation, 2024

⁴⁰ [Bayerisches Staatsministerium — AI Act Accelerator](#) — Behördenbericht, Dezember 2024

⁴¹ [Mittelstand-Digital Zentrum](#) — Behördenbericht, laufend

⁴² [BridgeAI — KMU-Pflichtschulung](#) — Branchenbericht, 2025

Offene Fragen und Ausblick

Harmonisierte Standards fehlen noch. Die technischen Normen von CEN/CENELEC, die konkretisieren, wie die Anforderungen umzusetzen sind, werden voraussichtlich nicht vor Ende 2026 verfügbar sein. Ohne diese Standards bleibt die praktische Compliance-Umsetzung für viele KMU abstrakt.

Vereinfachtes Dokumentationsformular für KMU: Artikel 11 sieht ein vereinfachtes Formular vor, das die EU-Kommission bereitstellen muss. Zum Zeitpunkt dieser Recherche (April 2026) ist es noch nicht veröffentlicht.

Nationale Durchführung in Deutschland: Die Bundesnetzagentur (BNetzA) ist als nationale Aufsichtsbehörde benannt, aber konkrete Durchsetzungsmodalitäten, Sandbox-Implementierung und Gebührenordnungen sind noch offen.

Digital Omnibus noch nicht final: Die vorgesehenen Erleichterungen (Fristverschiebung, vereinfachtes QMS, erweiterter KMU-Schutz auf Small Mid-Caps) befinden sich im Trilog-Verfahren. Die zyprische Ratspräsidentschaft strebt eine Einigung bis Mai 2026 an. KMU sollten vorsichtshalber die ursprünglichen Fristen im Blick behalten.

Widersprüchliche Kostenschätzungen: Die EU-Kommission beziffert Marginalkosten mit 6.000–7.000 EUR pro System, die Industrie rechnet mit 200.000–500.000 EUR Gesamtkosten. Der Unterschied erklärt sich durch QMS-Aufbau und organisatorische Kosten, die in den Kommissionsschätzungen fehlen.

Erstellt mit [Deep Researcher](#) von Leon Beckert